Funcionamiento de los Protocolos Criptográficos

Explicación del funcionamiento de los principales protocolos criptográficos utilizados para proteger la información durante su almacenamiento y transmisión

Nombre del grupo: DataMiners

Integrantes: Francisco Camacho, Lautaro Larrosa, Bruno Coirolo, Nicolas Pereira

Unidad curricular: Ciberseguridad

Docente(s): Carina Sindoni

Fecha de culminación del trabajo: 21/08/2026

Número de entrega: Segunda Entrega



Índice

1. Introducción 3
2. Protocolos y algoritmos criptográficos utilizados 3
3. Funcionamiento detallado de cada protocolo 4
4. Aplicación en el SGRSI 6
5. Referencias Bibliográficas 6

1. Introducción

El presente documento explica el funcionamiento de los principales protocolos y algoritmos criptográficos que protegen la información del Sistema de Gestión de Recursos y Soporte de Informática (SGRSI), tanto durante su almacenamiento como durante su transmisión. Para cada uno se describe su mecanismo interno de funcionamiento y el objetivo de seguridad —confidencialidad o integridad— que garantiza dentro de la tríada CIA.

2. Protocolos y algoritmos criptográficos utilizados

En la siguiente tabla se resumen los protocolos y algoritmos criptográficos aplicados en el sistema, la fase de la información que protegen (almacenamiento o transmisión) y el objetivo de seguridad que cumplen.

Protocolo / Algoritmo	Fase que protege	Objetivo (CIA)	Resumen de funcionamiento
bcrypt	Almacenamiento	Confidencialidad	Genera un hash adaptativo de la contraseña con un salt único por usuario.
TLS (HTTPS)	Transmisión	Confidencialidad e integridad	Cifra el canal de comunicación entre el navegador y el servidor con claves de sesión negociadas.
SHA-256	Almacenamiento y transmisión	Integridad	Genera una huella digital de longitud fija que permite detectar cualquier alteración de los datos.
HMAC	Transmisión	Integridad y autenticidad	Combina una función hash con una clave secreta para verificar que un mensaje no fue modificado ni falsificado.

3. Funcionamiento detallado de cada protocolo

3.1 Cifrado de contraseñas con bcrypt

bcrypt no es un algoritmo de cifrado reversible sino una función de hash adaptativa, basada en el cifrado Blowfish, pensada específicamente para contraseñas. Su funcionamiento sigue estos pasos:

- **Generación de un salt:** se crea un valor aleatorio de 128 bits, distinto para cada usuario, que se combina con la contraseña antes de aplicar el hash.
- **Factor de costo (work factor):** un número entero (por ejemplo 12) que indica cuántas veces se repite el algoritmo internamente (2 elevado a ese número), regulando cuánto tiempo de cómputo insume generar el hash.

- **Derivación del hash:** la contraseña y el salt se procesan mediante una versión modificada del algoritmo de expansión de clave de Blowfish (EksBlowfish), ejecutada repetidamente según el factor de costo, hasta obtener un valor de 184 bits.
- **Codificación final:** el resultado almacenado incluye, en un mismo string, el identificador del algoritmo, el factor de costo, el salt y el hash (por ejemplo "$2y$12$..."), de modo que no es necesario guardar el salt por separado.

En el inicio de sesión, el sistema toma el salt y el factor de costo del hash almacenado, vuelve a calcular el hash sobre la contraseña ingresada con esos mismos parámetros y compara el resultado. Como el proceso nunca se revierte, aunque la base de datos sea comprometida las contraseñas originales no quedan expuestas, y el factor de costo puede aumentarse con el tiempo para que el cálculo siga siendo costoso a medida que mejora el hardware disponible para atacar.

3.2 TLS / HTTPS

HTTPS es el protocolo HTTP ejecutado sobre TLS (Transport Layer Security), que cifra y autentica la comunicación entre el navegador y el servidor. Su funcionamiento se resume en dos etapas:

- **Negociación (handshake):** el cliente envía un "Client Hello" con los algoritmos que soporta; el servidor responde con su certificado digital, que contiene su clave pública firmada por una autoridad certificadora (CA). Mediante un intercambio de claves (por ejemplo Diffie-Hellman efímero), ambas partes acuerdan una clave de sesión simétrica sin transmitirla nunca en texto plano por la red.
- **Transmisión cifrada:** una vez establecida la clave de sesión, todo el tráfico se cifra con un algoritmo simétrico (habitualmente AES) en un modo autenticado como AES-GCM, que garantiza en simultáneo la confidencialidad de los datos y su integridad, detectando cualquier modificación en tránsito.

Antes de confiar en el servidor, el navegador valida la cadena de certificados hasta una autoridad certificadora reconocida, lo que evita ataques de intermediario (man-in-the-middle) y asegura que las credenciales y los datos del sistema viajan protegidos dentro de la red institucional.

3.3 Funciones hash criptográficas (SHA-256)

SHA-256 es una función hash que toma una entrada de cualquier tamaño y produce una salida fija de 256 bits. Sus propiedades principales son: es determinística (la misma entrada siempre produce la misma salida), unidireccional (no se puede reconstruir la entrada a partir de la salida) y presenta efecto avalancha, es decir que un cambio mínimo en la entrada altera por completo el resultado. Estas propiedades permiten usarla para verificar la integridad de archivos, respaldos o registros: si el hash calculado sobre un dato no coincide con el hash almacenado previamente, significa que el dato fue alterado.

3.4 HMAC (Hash-based Message Authentication Code)

HMAC combina una función hash (como SHA-256) con una clave secreta compartida para producir un código de autenticación de mensaje. Se calcula aplicando la función hash dos veces sobre el mensaje combinado con variaciones de la clave secreta. A diferencia de un hash simple, HMAC no solo permite verificar que un mensaje no fue modificado en tránsito, sino también confirmar que fue generado por alguien que posee la clave secreta, aportando integridad y autenticidad en simultáneo. Este mecanismo forma parte del funcionamiento interno de TLS y puede utilizarse para validar la integridad de solicitudes entre servicios.

4. Aplicación en el SGRSI

El sistema SGRSI aplica estos protocolos de forma combinada para cubrir tanto el almacenamiento como la transmisión de la información. Las contraseñas de los usuarios se almacenan utilizando bcrypt, a través de la función password_hash de PHP con el algoritmo PASSWORD_BCRYPT, de modo que ni siquiera un acceso directo a la base de datos expone las credenciales originales. Todas las comunicaciones entre el navegador y el servidor dentro de la intranet institucional se realizan mediante HTTPS, protegiendo tanto las credenciales de inicio de sesión como los datos de inventario, tickets y solicitudes mientras viajan por la red.

Estos mecanismos son consistentes con los medios de seguridad definidos en el documento de Objetivos de Seguridad Informática (cifrado de contraseñas mediante hashing y uso de HTTPS) y con las reglas del Protocolo de Ciberseguridad del proyecto: cualquier cambio futuro en la política de contraseñas o en la configuración de TLS debe reflejarse en ambos documentos.

5. Referencias Bibliográficas

Provos, N., & Mazières, D. (1999). A Future-Adaptable Password Scheme. USENIX Annual Technical Conference.

Rescorla, E. (2018). RFC 8446: The Transport Layer Security (TLS) Protocol Version 1.3. Internet Engineering Task Force.

National Institute of Standards and Technology. (2015). FIPS 180-4: Secure Hash Standard.

Krawczyk, H., Bellare, M., & Canetti, R. (1997). RFC 2104: HMAC — Keyed-Hashing for Message Authentication. Internet Engineering Task Force.

OWASP Foundation. (2023). Password Storage Cheat Sheet. https://owasp.org/www-project-cheat-sheets/